

Cybersecurity & Blockchain

KGSP Enrichment [Week 3 & 4 – 2026]





Mudassar Aslam

(FHEA, PhD Cybersecurity)

Associate Professor of Cybersecurity & Program Director,
School of Engineering, Computing and Mathematics,
Oxford Brookes University,
Oxford, United Kingdom.
maslam@brookes.ac.uk

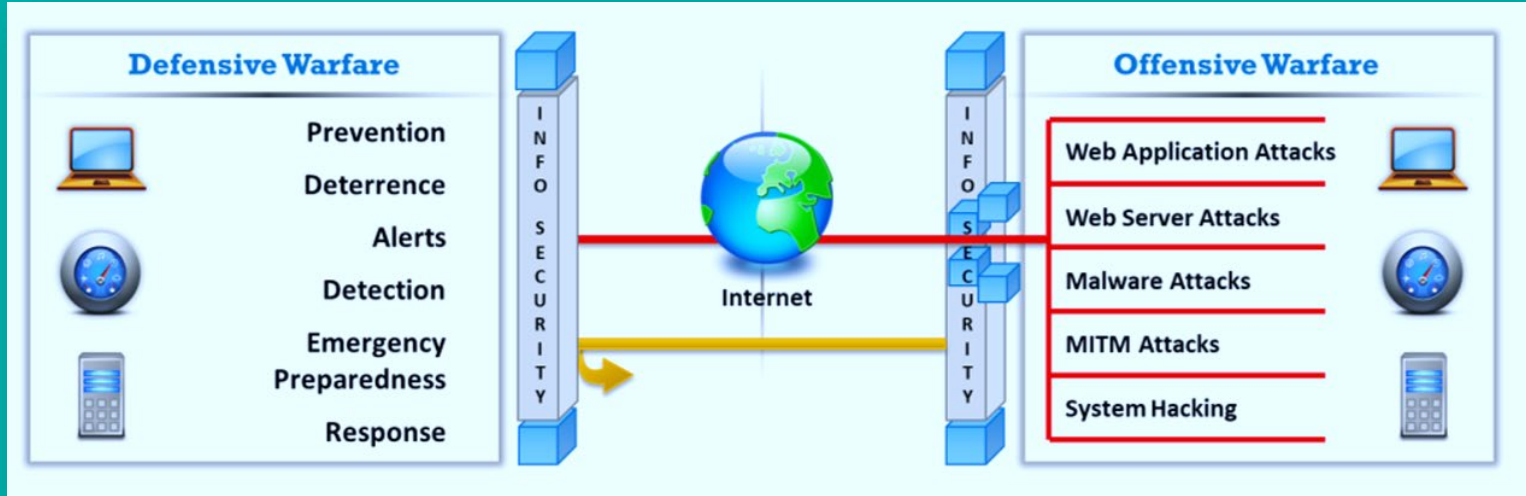
www.mudassir.info



Day 06 – Offensive Security



Security Approaches



Defensive Security - The Protective Shield



- Defensive security focuses on protecting systems, networks, and data from cyberattacks and unauthorized access through prevention and incident response.
 - **Prevention:** Deploy security controls like firewalls, antivirus, and encryption to block threats
 - **Layered Defense:** Implement multiple security measures to create defense-in-depth strategy
 - **Real-Time Monitoring:** Detect suspicious activities and potential breaches as they occur
 - **Incident Response:** React quickly to security breaches to minimize damage and restore systems

Mindset: Build walls, monitor constantly, and respond swiftly to threats



Key Defensive Security Measures (1/2)

Firewalls

- Act as gatekeepers, filtering incoming/outgoing traffic
- Block malicious connections before they reach systems
- Can be hardware or software-based

Encryption

- Converts readable data into unreadable code using cryptographic keys
- Only authorized users with keys can decrypt
- Protects data in transit and at rest

Authentication & Authorization

- Verifies user identity (username/password, MFA, biometrics)
- Ensures only authorized personnel access specific resources
- Prevents unauthorized access

Key Defensive Security Measures (2/2)

Security Monitoring & SIEM

- Continuously monitors networks and systems for suspicious activities
- Logs events for analysis
- Detects breaches in real-time using automated alerts

Offensive Security - The Proactive Approach



- Offensive security involves actively searching for vulnerabilities and weaknesses in systems before malicious actors can exploit them.
- **Find Before They Do:** Identify security flaws before cybercriminals discover and exploit them
- **Ethical Hacking:** Conduct authorized penetration tests to evaluate system defenses
- **Controlled Simulations:** Perform safe, legal attacks under strict guidelines to test security measures
- **Improve Defenses:** Provide detailed reports with recommendations to strengthen security posture

Mindset: Think like an attacker to stay one step ahead



Offensive vs Defensive - Two Sides of Security

Offensive Security (Proactive)

- Acts like an attacker to find flaws before criminals do
- Tests defenses through authorized attacks
- Identifies weaknesses in systems
- Mindset: "How can I break in?"

 *Best organizations use BOTH approaches together for comprehensive security!*

Defensive Security (Protective)

- Builds walls and monitors for threats
- Responds to breaches quickly
- Prevents unauthorized access and minimizes damage
- Mindset: "How do I protect the system?"

Network Threats & Attacks



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology

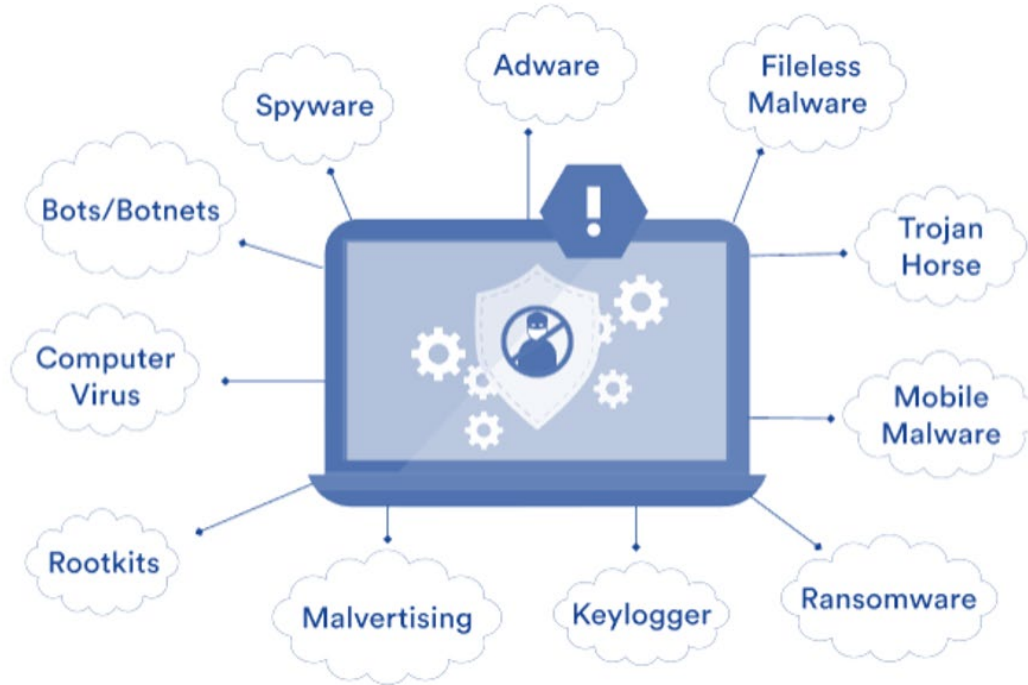
Attackers Motives, Goals and Objectives

- Disrupt business continuity
- Perform information theft
- Manipulating data
- Create fear and chaos by disrupting critical infrastructures
- Bring financial loss to the target
- Propagate religious or political beliefs
- Achieve a state's military objectives
- Damage the reputation of the target
- Take revenge
- Demand ransom

Malware - Malicious Software

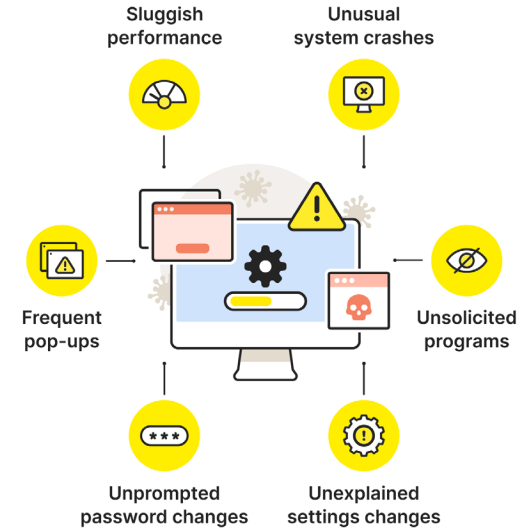
- One of the most significant threat to computer security
- Malware objects infect computer systems and then perform some type of **evil/malicious action**
 - stealing information (e.g. credit card details, tax returns)
 - damaging data (e.g. encrypt for ransom)
 - disrupting normal use of the system (e.g. monitor keystrokes)
- Every piece of malware will have two components:
 - Propagation mechanism
 - Payload (evil/malicious action)

Types of Malware



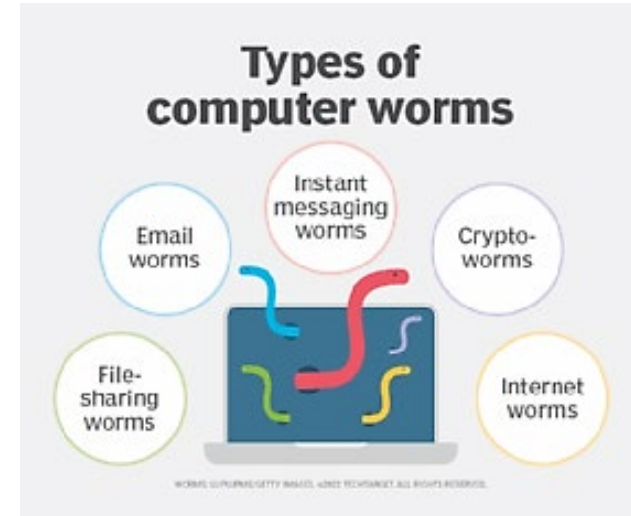
Virus

- The term virus is often **mistakenly** used for any type of malware
- Computer viruses take their name from **biological viruses**
- The defining characteristic of a virus is that it **spreads** from system to system based on some type of **user action**
 - opening an email attachment
 - clicking a link to a malicious website
 - inserting an infected USB drive into a system
- Cannot spread without user action -> User education can protect from viruses



Worms

- Worms **spread** from system to system **without user interaction**
- Worms implement their spread strategy + malicious action
- Worms **exploit system vulnerabilities**
- Infect systems without the user doing anything
- Once a system is infected, worm uses that system as a new base for spreading to other parts of the local area network or the broader Internet.
- Protection
 - keeping systems updated with the most recent operating system and application patches



Trojan Horse

- Named after the story of the Trojan horse from the 12th century B.C.
- The Greek army, which had laid siege to the **city of Troy** for 10 years, built a gigantic wooden **horse and hid soldiers inside** of it. The rest of the army then pretended to sail away, leaving the horse for the Trojans to claim as a trophy. The Trojans opened their city walls and brought the horse inside. That night, the Greek army poured out of the horse and destroyed the city.
- A Trojan horse malware pretends to be legitimate piece of software that a user might want to download and install
- When the user runs the program, it does **perform as expected**; however, the Trojan horse also carries a **malicious hidden payload** that performs some unwanted action behind the scenes.
- Protection
 - Application Control provides a good defense against this threat by validating software hashes/integrity



RANSOMWARE



Description

Ransomware encrypts the victim's data or locks them out of their systems, demanding payment (usually in cryptocurrency) for restoration



Example

WannaCry, which targeted Microsoft Windows systems



SPYWARE



Description

Spyware secretly monitors user activity, collecting sensitive information such as passwords, keystrokes, and browsing habits



Example

Keyloggers that record keystrokes to steal credentials



ADWARE



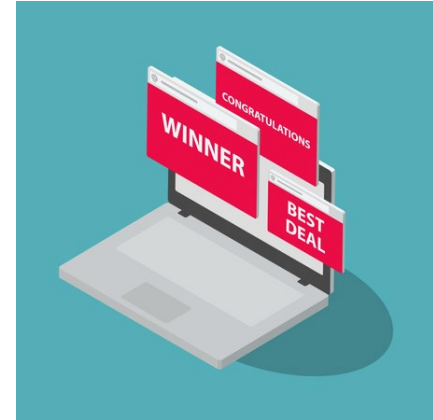
Description

Adware displays unwanted advertisements on a user's device, often bundled with free software. Some adware can track user activity



Example

Software that redirects browser searches to advertising websites



ROOTKITS



Description

Rootkits are designed to gain administrative-level control of a system while hiding their presence. They can hide other malware and remain undetected for long periods



Example

Kernel-level rootkits that embed themselves deep within the operating system



BOTNETS



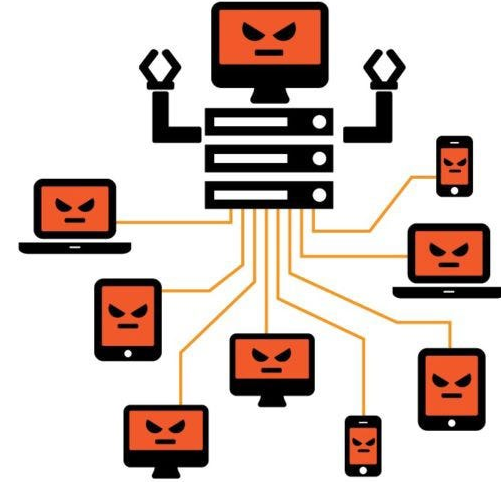
Description

Botnets are networks of infected computers (bots) controlled remotely by attackers. These networks are used to perform large-scale attacks, such as Distributed Denial of Service (DDoS) attacks.



Example

The Mirai botnet, which compromised IoT devices



FILELESS MALWARE



Description

Fileless malware operates in memory rather than writing malicious code to disk. This makes it harder to detect using traditional antivirus software



Example

Attacks that exploit PowerShell scripts or Windows Management Instrumentation (WMI)



SCAREWARE



Description

Scareware tricks users into believing their system is infected, prompting them to purchase fake security software or services



Example

Fake antivirus alerts that direct users to malicious websites



ROGUE SECURITY SOFTWARE



Description

This type of malware pretends to be legitimate security software but actually installs more malware or demands payment for removal of non-existent threats.



Example

Fake antivirus programs that claim to find numerous infections



CRYPTOJACKERS



Description

Cryptojacking malware covertly uses a victim's computer resources to mine cryptocurrency, slowing down the system and increasing power consumption



Example

CoinMiner scripts injected into websites



LOGIC BOMBS



Description

Logic bombs are malicious code that triggers a harmful action when specific conditions are met, such as a particular date or the removal of an employee from a payroll system.



Example

Time bombs that execute after a set period



RATS (REMOTE ACCESS TROJANS)



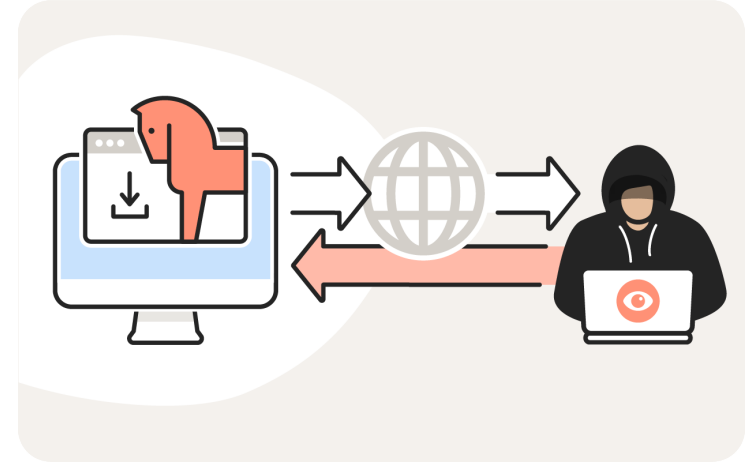
Description

RATs allow attackers to take control of the infected computer remotely. They can be used to steal information, manipulate files, or deploy additional malware.



Example

DarkComet RAT



KEYLOGGERS



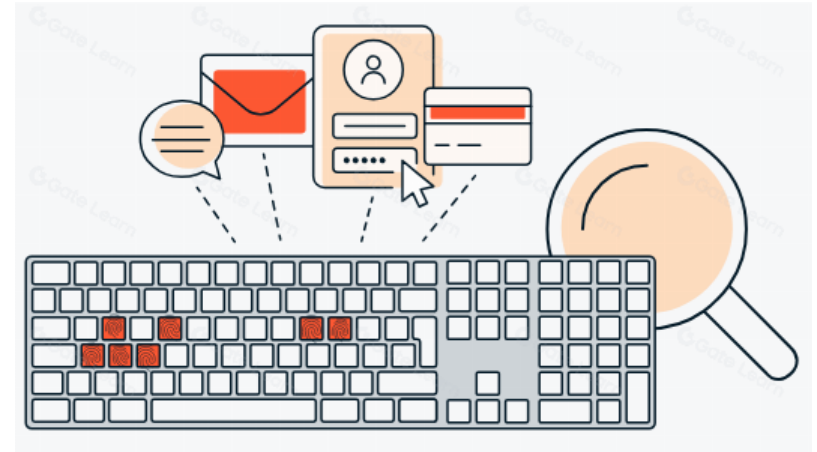
Description

Keyloggers capture keystrokes on a victim's device, often to steal passwords, credit card numbers, or other sensitive information



Example

Hardware or software keyloggers



EXPLOIT KITS



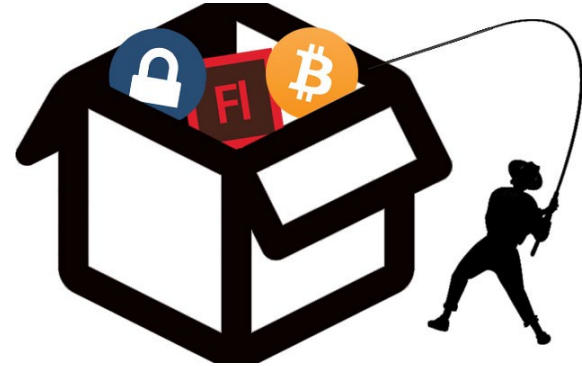
Description

Exploit kits are toolkits used by attackers to exploit known vulnerabilities in software or systems, often delivered through drive-by downloads.



Example

Angler Exploit Kit.



PHISHING MALWARE



Description

This type of malware is delivered via phishing emails or messages, tricking users into downloading malicious software by pretending to be a legitimate communication.



Example

Malicious attachments in phishing emails





Types of Attacks



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology



Passive Attacks (1/5)

- Intercepting and Monitoring network traffic and data flow
- Do not tamper with the data
- Reconnaissance on network activities using sniffers
- Very difficult to detect as the attacker has no active interaction
- Capture data or files being transmitted in the network
 - obtain information such as unencrypted data in transit
 - clear-text credentials
 - other sensitive information
- Gathered information could be used in performing active attacks

Examples

- Footprinting
- Sniffing
- Eavesdropping
- Network traffic analysis
- Decryption of weakly encrypted traffic

Active Attacks (2/5)

- Active attacks tamper with the data in transit
- Disrupt communication or services between the systems to bypass or break into secured systems
- Attackers send traffic actively that can be detected
- Performed on the target network to exploit the information in transit
- Penetrate or infect the target's internal network and gain access to a remote system to compromise the internal network.

Password-based attacks

Session hijacking

Man-in-the-Middle attack

DNS and ARP poisoning

Compromised-key attack

Firewall and IDS attack

Profiling

Arbitrary code execution

Privilege escalation

Backdoor access

Cryptography attacks

SQL injection

XSS attacks

Directory traversal attacks

Exploitation of application and OS software

Examples

- Denial-of-service (DoS)
- Bypassing protection mechanisms
- Malware attacks
- Modification of information
- Spoofing
- Replay

Close-in Attacks (3/5)

- Attacker is in close physical proximity with the target system or network.
- The main goal of performing this type of attack is to gather or modify information or disrupt its access

Examples

- Social engineering
- Eavesdropping
- Shoulder surfing
- Dumpster diving

Insider Attacks (4/5)

- Performed by trusted persons who have physical access to the critical assets of the target
- Privileged access is used to violate rules or intentionally cause a threat to the organization's information or information systems.
- Insiders can easily bypass security rules, corrupt valuable resources, and access sensitive information
- Misuse the organization's assets to directly affect the confidentiality, integrity, and availability of information systems

Examples

- Eavesdropping and wiretapping
- Theft of physical devices
- Social engineering
- Data theft
- Spoliation
- Pod slurping
- Planting Keyloggers, Backdoors, malware

Distribution Attacks (5/5)

- Distribution attacks occur when attackers tamper with hardware or software prior to installation
- Attackers tamper the hardware or software at its source or when it is in transit
- **Examples**
 - backdoors created by software or hardware vendors at the time of manufacture
 - Modification of software or hardware during production
 - Modification of software or hardware during distribution
 - Supply Chain

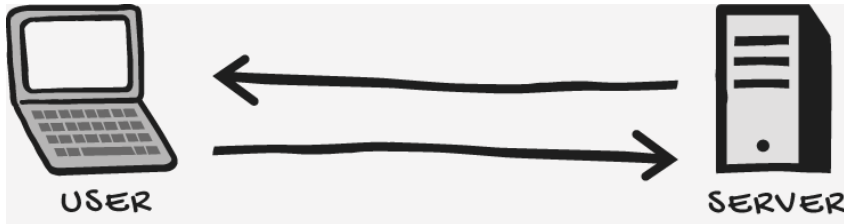
1. EAVESDROPPING ATTACKS

- Attacker can gain physical or logical access to the network and eavesdrop on communications between two systems
- Allow the attacker to potentially decrypt encrypted communications and view confidential information without the sender's knowledge or consent.
- Communication path is compromised
 - tapping into a network device or cable
 - conducting a specialized attack to trick a system into sending traffic directly to an attacker instead of the intended recipient

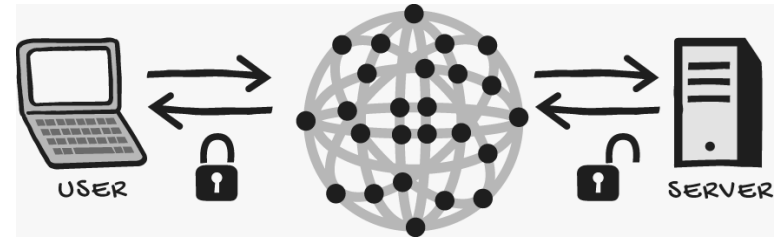
ON-PATH ATTACKS

- Inserting an attacker in between the client and the server
 1. man-in-the-middle (MitM)
 2. man-in-the-browser (MitB) attacks

Perception



Reality



8 Types of MITM Attacks: <https://cheapsslsecurity.com/blog/types-of-man-in-the-middle-attacks/>

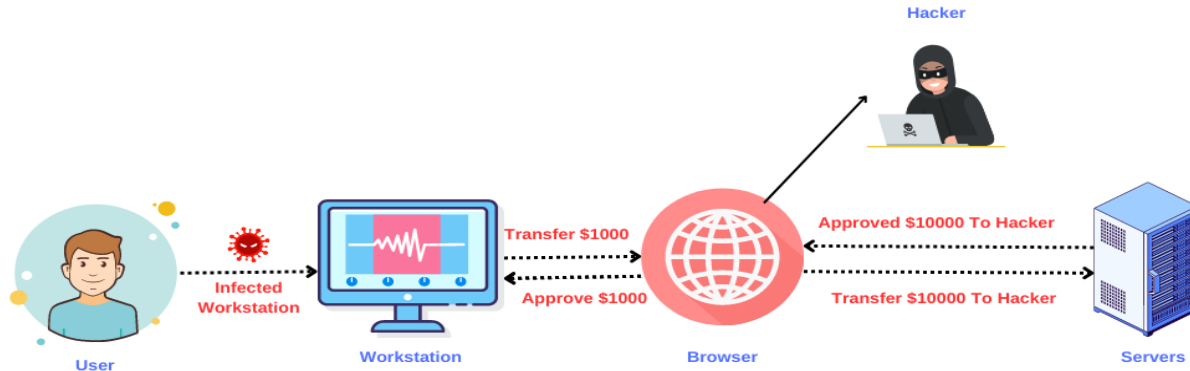
1a - Man-in-the-Middle (MITM) Attack

- simple eavesdropping is easily defeated by encryption
- Attacker tricks the sending system during the initial communication
- by reconfiguring a network device or by using DNS or ARP poisoning



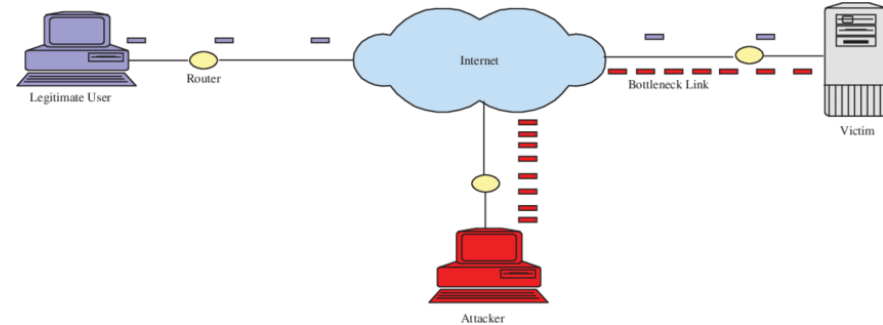
1b - Man-in-the-Browser Attacks

- The man-in-the-browser attack is a variation on the man-in-the-middle attack
- Attacker compromises the user's **web browser** or a **browser plugin** or **extension** to gain access to web communications.
- The major difference is that the attacker isn't present on a different network device from the user and server.
- The attacker is actually present on the user's computer.



2 - DENIAL-OF-SERVICE (DOS) ATTACKS

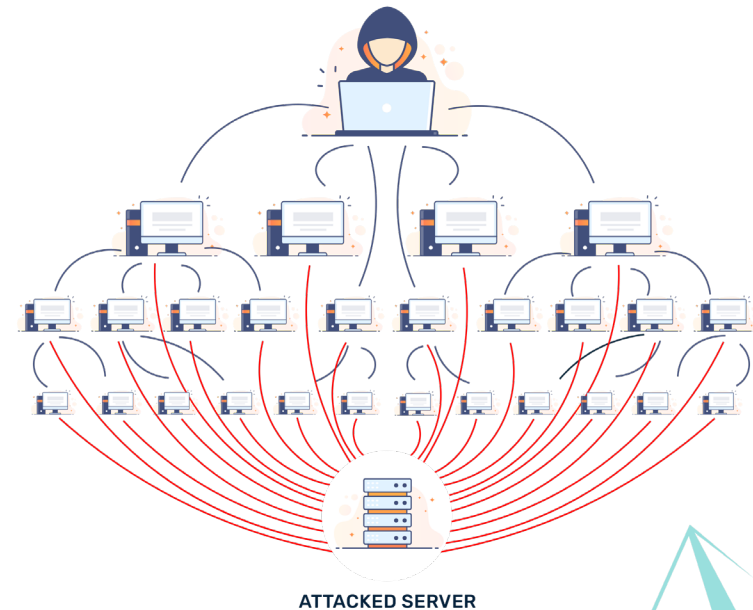
- Attack on the **Availability** service
- Attacker sends thousands or **millions of requests** to a **network**, **server**, or **application**, overwhelming it and making it unable to answer any requests
- Very difficult to distinguish DoS attack requests from legitimate traffic.
- Challenges for the attacker:
 - 1) require large amounts of **bandwidth**
 - 2) Victim can easily block the attack. Once the victim recognizes they are under attack, they can simply **block the IP addresses** of the attackers.



DISTRIBUTED DENIAL-OF-SERVICE (DDOS) ATTACKS



- Attacker uses **botnet** which is a network of millions of compromised nodes
 - A compromised node could be a computer, or an IoT device
 - Such nodes are called **zombies**
 - Botnet is activated using a **Command-and-Control** mechanism
- Difficult to differentiate between legitimate and attack traffic



3 – SIDE CHANNEL ATTACKS

- Computer systems generate characteristic footprints of activity, such as changes in **processor utilization**, **power consumption**, or **electromagnetic radiation**...
- Side-channel attacks seek to use this information to **monitor** system activity and **retrieve** information that is actively being used.
- Side-channel attack factors/vector
 - Electromagnetic, Acoustic (key tapping sounds can determine key pressed), Power, Timing (different times define the signature of an activity)
- Becoming easier because of Increasing sensitivity of measuring equipment's, Machine Learning techniques

✓ *AlphaLogger: detecting motion-based side-channel attack using smartphone keystrokes*
(<https://link.springer.com/article/10.1007/s12652-020-01770-0>)

✓ *New Attack Lets Android Apps Capture Loudspeaker Data Without Any Permission*
(<https://thehackernews.com/2019/07/android-side-channel-attacks.html>)



Practical: Pentesting Demo



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology





جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology